CONFIDENTIAL

Vulnerability Assessment & Penetration Testing

Web Application Security Assessment Report

Client: Devarsons Industries Pvt. Ltd.

Target: https://www.devarsons.com

Report date: 03 October 2026

Version: 1.0 (Final)

This document contains confidential information intended solely for the named client. Do not distribute without authorisation.

Document Control

Document title	Vulnerability Assessment and Penetration Testing (VAPT) Report
Client	Devarsons Industries Pvt. Ltd.
Application in scope	https://www.devarsons.com
Assessment type	Black-box web application security assessment (external, unauthenticated)
Assessment date	03 October 2026
Report version	1.0 - Final
Classification	Confidential

Table of Contents

Document Control 2

Table of Contents 2

1. Executive Summary 3

2. Scope and Methodology 4

3. Summary of Findings 6

4. Detailed Findings 7

5. Informational Observations 13

6. Remediation Roadmap 14

Appendix A - References 15

Appendix B - Disclaimer 15

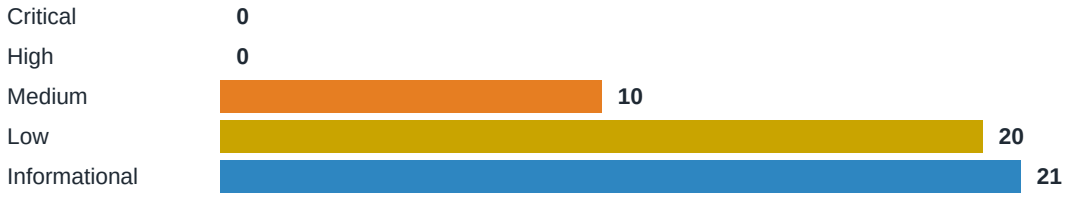
1. Executive Summary

Devarsons Industries Pvt. Ltd. engaged a security assessment of its public website **www.devarsons.com** to identify security weaknesses that could be exploited by an external attacker. The assessment was carried out on 03 October 2026 using a black-box approach, without credentials or prior knowledge of the internal environment.

Overall result. No Critical or High severity vulnerabilities were identified. The assessment produced **14 distinct findings** (51 individual occurrences): **4 Medium**, **5 Low** and **5 Informational**. The majority relate to missing HTTP security headers and transport-security hardening rather than to flaws in application logic, which is consistent with a largely static, content-oriented website sitting behind a CDN.

0	0	4	5	5
Critical	High	Medium	Low	Informational

Number of occurrences by severity (total: 51)



Key observations

- **Transport security is incomplete:** HSTS is not enabled and content remains reachable over plain HTTP (VAPT-05, VAPT-06).
- **Browser-side protections are absent:** no Content-Security-Policy, anti-clickjacking or X-Content-Type-Options headers are set (VAPT-01, 02, 07).
- **Third-party dependency risk:** a script is loaded from an external host without Subresource Integrity, and that host returns a wildcard CORS policy (VAPT-03, 04, 08).
- **Positive points:** the site is served over HTTPS behind a CDN/reverse proxy, no server version banners are exposed, and no injection, authentication or access-control flaws were identified in the automated tests performed.

Recommendation in brief

Most findings can be closed by adding a small set of HTTP response headers and an HTTP-to-HTTPS redirect at the web server or CDN layer. This is a low-effort change (estimated under one working day) that would remove all Medium-rated findings except the third-party items. A prioritised remediation plan is provided in Section 6.

2. Scope and Methodology

2.1 Scope

Host / URL	Description	Ownership
https://www.devarsons.com	Primary website (HTTPS)	Client
http://www.devarsons.com	Primary website (HTTP)	Client
https://img1.wsimg.com	Third-party asset host referenced by the site (observed only; not actively attacked)	Third party

Approximately 50 distinct endpoints (pages, scripts, stylesheets, fonts and images) were discovered and examined. Only GET requests were issued. No denial-of-service, social-engineering or physical tests were performed.

2.2 Methodology

The assessment followed an approach aligned with the **OWASP Web Security Testing Guide (WSTG)** and the **OWASP Top 10**, in the following phases:

Phase	Activity
1. Reconnaissance	Identification of hosts, technology stack, CDN presence and publicly exposed files (robots.txt, sitemap.xml).
2. Crawling and mapping	Spidering of the site to enumerate pages, scripts, stylesheets and external dependencies.
3. Passive analysis	Inspection of all observed requests and responses for missing security headers, information disclosure, cookie and caching issues.
4. Active testing	Automated active checks, including HTTP/HTTPS parity testing and User-Agent variation testing.
5. Analysis and rating	Triage of results, removal of duplicates, risk rating and remediation guidance.

2.3 Tooling and limitations

Testing was performed with an industry-standard automated dynamic application security scanner operating in passive and active modes. Findings were then consolidated and reviewed. Readers should note the following limitations:

- The assessment is a point-in-time view; the security posture may change as the site or its infrastructure changes.
- The target is an unauthenticated, content-oriented website. No login areas, APIs or forms processing user data were identified in scope, so authentication, authorisation and business-logic testing were not applicable.
- Automated results can contain false positives and cannot replace in-depth manual testing. Low-confidence findings are flagged accordingly.
- Third-party hosts were observed but not attacked; findings relating to them must be addressed with the respective provider.

2.4 Risk rating model

Rating	Definition	Suggested remediation window
Critical / High	Directly exploitable with severe impact on confidentiality, integrity or availability.	Immediately / within 7 days
Medium	Weakness that reduces defence-in-depth or can be exploited under specific conditions.	Within 30 days
Low	Minor weakness or hardening gap with limited impact on its own.	Within 60-90 days
Informational	No direct security impact; observation, best-practice or context for the reviewer.	As part of routine maintenance

Ratings reflect the scanner's severity and confidence values, adjusted for the context of a public, non-transactional website.

3. Summary of Findings

ID	Finding	Severity	Confidence	Occurrences
VAPT-01	Content Security Policy (CSP) Header Not Set	**Medium**	High	4
VAPT-02	Missing Anti-clickjacking Header	**Medium**	Medium	2
VAPT-03	Cross-Domain Misconfiguration (Permissive CORS Policy)	**Medium**	Medium	2
VAPT-04	Sub Resource Integrity (SRI) Attribute Missing	**Medium**	High	2
VAPT-05	Strict-Transport-Security (HSTS) Header Not Set	**Low**	High	6
VAPT-06	HTTPS Content Available via HTTP	**Low**	Medium	5
VAPT-07	X-Content-Type-Options Header Missing	**Low**	Medium	6
VAPT-08	Cross-Domain JavaScript Source File Inclusion	**Low**	Medium	2
VAPT-09	Timestamp Disclosure - Unix	**Low**	Low	1
INFO-01	Information Disclosure - Suspicious Comments	**Info**	Medium	6
INFO-02	Modern Web Application	**Info**	Medium	2
INFO-03	Re-examine Cache-control Directives	**Info**	Low	3
INFO-04	Retrieved from Cache	**Info**	Medium	5
INFO-05	User Agent Fuzzer	**Info**	Medium	5

Occurrences indicate the number of individual requests/pages on which the issue was observed.

Standards mapping

Finding	CWE	OWASP Top 10 category
VAPT-01 Content Security Policy (CSP) Header Not Set	CWE-693	A05:2021 Security Misconfiguration
VAPT-02 Missing Anti-clickjacking Header	CWE-1021	A05:2021 Security Misconfiguration
VAPT-03 Cross-Domain Misconfiguration (Permissive CORS Policy)	CWE-264	A01:2021 Broken Access Control
VAPT-04 Sub Resource Integrity (SRI) Attribute Missing	CWE-345	A05:2021 Security Misconfiguration
VAPT-05 Strict-Transport-Security (HSTS) Header Not Set	CWE-319	A05:2021 Security Misconfiguration
VAPT-06 HTTPS Content Available via HTTP	CWE-311	A04:2025 / A02:2021 Cryptographic Failures
VAPT-07 X-Content-Type-Options Header Missing	CWE-693	A05:2021 Security Misconfiguration
VAPT-08 Cross-Domain JavaScript Source File Inclusion	CWE-829	A08:2021 Software and Data Integrity Failures
VAPT-09 Timestamp Disclosure - Unix	CWE-497	A01:2021 Broken Access Control

4. Detailed Findings

Findings are ordered by severity. Each entry contains a description, supporting evidence, business impact and recommended remediation.

VAPT-01	Content Security Policy (CSP) Header Not Set				MEDIUM
Severity	Medium	**Confidence**	High	**Occurrences**	4
CWE	CWE-693	**OWASP**	A05:2021 Security Misconfiguration		

Affected URL(s)

`https://www.devarsons.com/sitemap.xml`

Observed in 4 occurrence(s) in total; the same configuration applies across the site.

Description

The web server does not send a **Content-Security-Policy** response header. CSP is a browser-enforced control that restricts which sources of scripts, styles, frames, images and other content a page may load. Without it, the browser has no policy to fall back on if an attacker manages to inject content into a page.

Evidence

```
Response header section contains no Content-Security-Policy header (observed on a 404 response for
/sitemap.xml; the same condition applies site-wide).
```

Impact

If a cross-site scripting or content-injection flaw is ever introduced, the absence of CSP removes a key layer of defence and makes data theft, defacement or malware distribution easier to achieve.

Recommendation

- Define and deploy a Content-Security-Policy header on all HTML responses, starting in report-only mode to avoid breaking the site.
- Allow only the origins actually required (own domain plus any trusted third-party script and font hosts) and avoid `unsafe-inline` / `unsafe-eval` where possible.
- Tighten the policy gradually after reviewing violation reports.

Example configuration:

```
Content-Security-Policy: default-src 'self'; script-src 'self' https://img1.wsimg.com;
  style-src 'self' 'unsafe-inline'; img-src 'self' data:; font-src 'self' data:;
  frame-ancestors 'self'; base-uri 'self'; object-src 'none'
```

References

https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP
https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html

VAPT-02	Missing Anti-clickjacking Header				MEDIUM
Severity	Medium	**Confidence**	Medium	**Occurrences**	2
CWE	CWE-1021	**OWASP**	A05:2021 Security Misconfiguration		

Affected URL(s)

`https://www.devarsons.com/`

Observed in 2 occurrence(s) in total; the same configuration applies across the site.

Description

The application response protects against neither "clickjacking" nor UI-redress attacks. Neither an **X-Frame-Options** header nor a CSP **frame-ancestors** directive is returned, so any third-party site can embed the pages inside a frame.

Evidence

```
Header checked: x-frame-options - not present in the response for https://www.devarsons.com/.
```

Impact

An attacker can overlay the site in a hidden frame and trick visitors into clicking on elements they cannot see. For a primarily informational site the direct impact is limited, but it becomes serious if forms or authenticated functions are added later.

Recommendation

- Send `X-Frame-Options: SAMEORIGIN` (or `DENY` if framing is never required) on all pages.
- Preferably also set CSP `frame-ancestors 'self'`, which supersedes X-Frame-Options in modern browsers.

Example configuration:

```
X-Frame-Options: SAMEORIGIN
Content-Security-Policy: frame-ancestors 'self'
```

References

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

VAPT-03	Cross-Domain Misconfiguration (Permissive CORS Policy)				MEDIUM
Severity	Medium	**Confidence**	Medium	**Occurrences**	2
CWE	CWE-264	**OWASP**	A01:2021 Broken Access Control		

Affected URL(s)

`https://img1.wsimg.com/traffic-assets/js/tccl.min.js`

Observed in 2 occurrence(s) in total; the same configuration applies across the site.

Description

A resource loaded by the website is served with **Access-Control-Allow-Origin: ***, which allows any origin to read the response through the browser. The affected host (img1.wsimg.com) is a third-party asset domain rather than the main application server.

Evidence

```
Access-Control-Allow-Origin: *
```

Impact

A wildcard CORS policy lets arbitrary websites read the resource from a visitor's browser. For public static JavaScript this is low-risk in practice, but the same setting on an endpoint that exposes IP-restricted or non-public data would be a data-exposure issue. The finding is rated Medium by the scanner and should be validated against what the resource actually returns.

Recommendation

- Confirm that the affected resource contains only public content and no sensitive data.
- If the host is under your control, replace the wildcard with an explicit list of trusted origins, or remove CORS headers entirely.
- If the host belongs to a third-party provider, record the item as an accepted/transferred risk and review the provider's security posture.

Example configuration:

```
Access-Control-Allow-Origin: https://www.devarsons.com
```

References

https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy

VAPT-04	Sub Resource Integrity (SRI) Attribute Missing				MEDIUM
Severity	Medium	**Confidence**	High	**Occurrences**	2
CWE	CWE-345	**OWASP**	A05:2021 Security Misconfiguration		

Affected URL(s)

`https://www.devarsons.com/`

Observed in 2 occurrence(s) in total; the same configuration applies across the site.

Description

The home page loads JavaScript from an external domain without an **integrity** attribute on the script tag. Subresource Integrity lets the browser verify that a fetched file has not been altered.

Evidence

```
<script src='https://img1.wsimg.com/traffic-assets/js/tccl.min.js'></script>
```

Impact

If the external host is compromised, or the file is altered in transit or at the CDN, malicious code would run with full access to the page and visitors' browsers without any warning (a supply-chain attack).

Recommendation

- Add `integrity="sha384-..."` together with `crossorigin="anonymous"` to every external script and stylesheet.
- Where the third-party file changes frequently and SRI is impractical, self-host a pinned copy of the file.

Example configuration:

```
<script src="https://img1.wsimg.com/traffic-assets/js/tccl.min.js"
        integrity="sha384-<base64-hash>" crossorigin="anonymous"></script>
```

References

https://developer.mozilla.org/en-US/docs/Web/Security/Defenses/Subresource_Integrity

VAPT-05	Strict-Transport-Security (HSTS) Header Not Set				LOW
Severity	Low	**Confidence**	High	**Occurrences**	6
CWE	CWE-319	**OWASP**	A05:2021 Security Misconfiguration		

Affected URL(s)

`https://www.devarsons.com/robots.txt`

Observed in 6 occurrence(s) in total; the same configuration applies across the site.

Description

HTTPS responses do not include the **Strict-Transport-Security** header, so browsers are not instructed to use HTTPS exclusively for this domain.

Evidence

```
No Strict-Transport-Security header in the response for https://www.devarsons.com/robots.txt.
```

Impact

Visitors who first type the plain-HTTP address, or follow an old http:// link, can be downgraded or intercepted on hostile networks (SSL-stripping / man-in-the-middle) before the redirect to HTTPS occurs.

Recommendation

- Enable HSTS with a max-age of at least one year once HTTPS works correctly on all subdomains.
- Consider `includeSubDomains` and, when ready, HSTS preloading.

Example configuration:

```
Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
```

References

https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html
https://datatracker.ietf.org/doc/html/rfc6797

VAPT-06	HTTPS Content Available via HTTP				LOW
Severity	Low	**Confidence**	Medium	**Occurrences**	5
CWE	CWE-311	**OWASP**	A04:2025 / A02:2021 Cryptographic Failures		

Affected URL(s)

`http://www.devarsons.com/assets/css/main.min.css`

Observed in 5 occurrence(s) in total; the same configuration applies across the site.

Description

Resources that are normally delivered over HTTPS can also be fetched over unencrypted HTTP; the HTTP version is served instead of being redirected to HTTPS.

Evidence

```
http://www.devarsons.com/assets/css/main.min.css returned content over plain HTTP.
```

Impact

Content served over HTTP can be read or modified by anyone on the network path. Altered CSS or JavaScript could be used to inject malicious content into pages loaded by visitors.

Recommendation

- Configure a permanent (301) redirect from HTTP to HTTPS for all paths on every hostname.
- Combine with HSTS (VAPT-05) so browsers stop attempting HTTP altogether.
- In Cloudflare, enable "Always Use HTTPS" and review the SSL/TLS mode (Full/Full Strict recommended).

Example configuration:

```
server {
    listen 80;
    server_name www.devarsons.com devarsons.com;
    return 301 https://$host$request_uri;
}
```

References

https://owasp.org/www-community/Security_Headers

VAPT-07	X-Content-Type-Options Header Missing				LOW
Severity	Low	**Confidence**	Medium	**Occurrences**	6
CWE	CWE-693	**OWASP**	A05:2021 Security Misconfiguration		

Affected URL(s)

`https://www.devarsons.com/robots.txt`

Observed in 6 occurrence(s) in total; the same configuration applies across the site.

Description

Responses do not include **X-Content-Type-Options: nosniff**, so some browsers may try to guess (sniff) the content type of a response instead of trusting the declared Content-Type.

Evidence

```
Header checked: x-content-type-options - not present.
```

Impact

MIME-sniffing can cause a browser to interpret a file as a different type (for example, treating user-influenced text as script), which can enable content-injection attacks.

Recommendation

- Add `X-Content-Type-Options: nosniff` to all responses.
- Make sure every response carries an accurate Content-Type header.

Example configuration:

```
X-Content-Type-Options: nosniff
```

References

https://owasp.org/www-community/Security_Headers

VAPT-08	Cross-Domain JavaScript Source File Inclusion				LOW
Severity	Low	**Confidence**	Medium	**Occurrences**	2
CWE	CWE-829	**OWASP**	A08:2021 Software and Data Integrity Failures		

Affected URL(s)

`https://www.devarsons.com/`

Observed in 2 occurrence(s) in total; the same configuration applies across the site.

Description

The home page includes JavaScript from a third-party domain. Code from external hosts runs with the same privileges as the site's own code.

Evidence

```
<script src='https://img1.wsimg.com/traffic-assets/js/tccl.min.js'></script>
```

Impact

The security of the site depends on the security of the external provider. A compromise of that provider would directly affect all visitors of the site.

Recommendation

- Keep third-party scripts to the minimum needed and load them only from trusted, contractually accountable providers.
- Apply SRI (VAPT-04) and restrict allowed script sources through CSP (VAPT-01).

VAPT-09	Timestamp Disclosure - Unix				LOW
Severity	Low	**Confidence**	Low	**Occurrences**	1
CWE	CWE-497	**OWASP**	A01:2021 Broken Access Control		

Affected URL(s)

`https://www.devarsons.com/assets/vendor/gsap/chroma.min.js`

Description

A value resembling a Unix timestamp was found in a response body. Disclosure of timestamps can occasionally help an attacker profile systems.

Evidence

```
2104542553 (evaluates to 2036-09-09 08:39:13)
```

Impact

Very low. The value appears inside a minified third-party JavaScript library (chroma.min.js) and is most likely a numeric constant of the library rather than server-generated data. It is considered a probable false positive.

Recommendation

- Manually confirm that the value is not sensitive; no action is normally required for library constants.

References

https://cwe.mitre.org/data/definitions/200.html

5. Informational Observations

The items below carry no direct security impact but are recorded for completeness and for use in future testing.

ID	Observation	Details	Suggested action
INFO-01	**Information Disclosure - Suspicious Comments** (6 occurrences)	HTML comments such as `<!-- nice select css -->` matched a keyword pattern. The comments reviewed only describe CSS/JS includes and contain no credentials or internal details.	Strip developer comments from production builds as a hygiene measure.
INFO-02	**Modern Web Application** (2 occurrences)	The site uses links without conventional href attributes (e.g. JavaScript-driven elements), which indicates a script-heavy front end. Noted for test coverage; not a vulnerability.	No action required. Use client-side/crawler-aware testing for deeper manual review.
INFO-03	**Re-examine Cache-control Directives** (3 occurrences)	Static content such as robots.txt is returned with `max-age=14400`. Acceptable for static assets.	Ensure dynamic or user-specific pages are served with no-store and static assets use explicit public, max-age directives.
INFO-04	**Retrieved from Cache** (5 occurrences)	Static assets (e.g. CSS libraries) were served from a shared cache / CDN edge, which is expected behaviour behind a CDN.	Confirm that no personalised or sensitive content can be cached by the CDN.
INFO-05	**User Agent Fuzzer** (5 occurrences)	Requests sent with a legacy browser User-Agent were compared with the baseline response to detect device- or crawler-specific behaviour.	Verify that no hidden or alternate content is served to specific user agents.

Environment notes

- The site is delivered through a CDN / reverse proxy (response header `Server: cloudflare`), which provides a convenient central place to apply the security headers recommended in this report.
- Non-existent paths (e.g. /sitemap.xml) correctly return HTTP 404 with a minimal body and no stack traces or version information.
- The legacy certification text and dated references in the page content (e.g. outdated ISO / OHSAS standard names) are a content-accuracy matter, not a security finding, but should be reviewed by the business.

6. Remediation Roadmap

Priority	Action	Addresses	Effort	Target
1	Redirect all HTTP traffic to HTTPS and enable HSTS	VAPT-05, VAPT-06	Low	30 days
2	Add X-Frame-Options / frame-ancestors and X-Content-Type-Options headers	VAPT-02, VAPT-07	Low	30 days
3	Design and roll out a Content-Security-Policy (report-only first)	VAPT-01	Medium	30 days
4	Add SRI to external scripts or self-host them; review third-party CORS and script usage	VAPT-03, 04, 08	Low-Medium	30 days
5	Remove developer comments, review caching directives, confirm timestamp finding	VAPT-09, INFO-01, 03	Low	60-90 days

Consolidated header baseline

The following baseline can be applied at the web server or CDN layer and closes VAPT-01, 02, 05 and 07 in one change. Test in a staging environment (CSP in report-only mode first) before enforcing.

```
# Nginx example (add inside the server block for HTTPS)
add_header Strict-Transport-Security "max-age=31536000; includeSubDomains" always;
add_header X-Content-Type-Options "nosniff" always;
add_header X-Frame-Options "SAMEORIGIN" always;
add_header Content-Security-Policy-Report-Only
    "default-src 'self'; script-src 'self' https://img1.wsimg.com;
    style-src 'self' 'unsafe-inline'; img-src 'self' data:; font-src 'self' data:;
    frame-ancestors 'self'; base-uri 'self'; object-src 'none'" always;

# Apache example
Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains"
Header always set X-Content-Type-Options "nosniff"
Header always set X-Frame-Options "SAMEORIGIN"
```

If headers are managed at the CDN, the same values can be configured through response-header transform rules, and "Always Use HTTPS" can be enabled in the CDN dashboard.

Retest

After remediation, a retest is recommended to verify closure of all Medium and Low findings and to obtain an updated report.

7. Conclusion

The security posture of www.devarsons.com is **reasonable for a public information website**: no Critical or High risk vulnerabilities were found and the identified issues are configuration-level hardening gaps. Implementing the recommended headers, enforcing HTTPS end-to-end and tightening the handling of third-party scripts would bring the site in line with current industry best practice and significantly reduce its exposure to client-side attacks.

Appendix A - References

- OWASP Top 10 - https://owasp.org/Top10/
- OWASP Web Security Testing Guide - https://owasp.org/www-project-web-security-testing-guide/
- OWASP Secure Headers Project - https://owasp.org/www-project-secure-headers/
- MDN Web Docs: HTTP security headers - https://developer.mozilla.org/en-US/docs/Web/Security
- MITRE CWE - https://cwe.mitre.org/
- RFC 6797 - HTTP Strict Transport Security (HSTS)

Appendix B - Disclaimer

This report reflects the security status of the in-scope systems at the time of testing and is based on the methods described in Section 2. It does not guarantee that the systems are free of vulnerabilities. The report is confidential and intended solely for Devarsons Industries Pvt. Ltd.; reproduction or disclosure to third parties without written consent is prohibited.